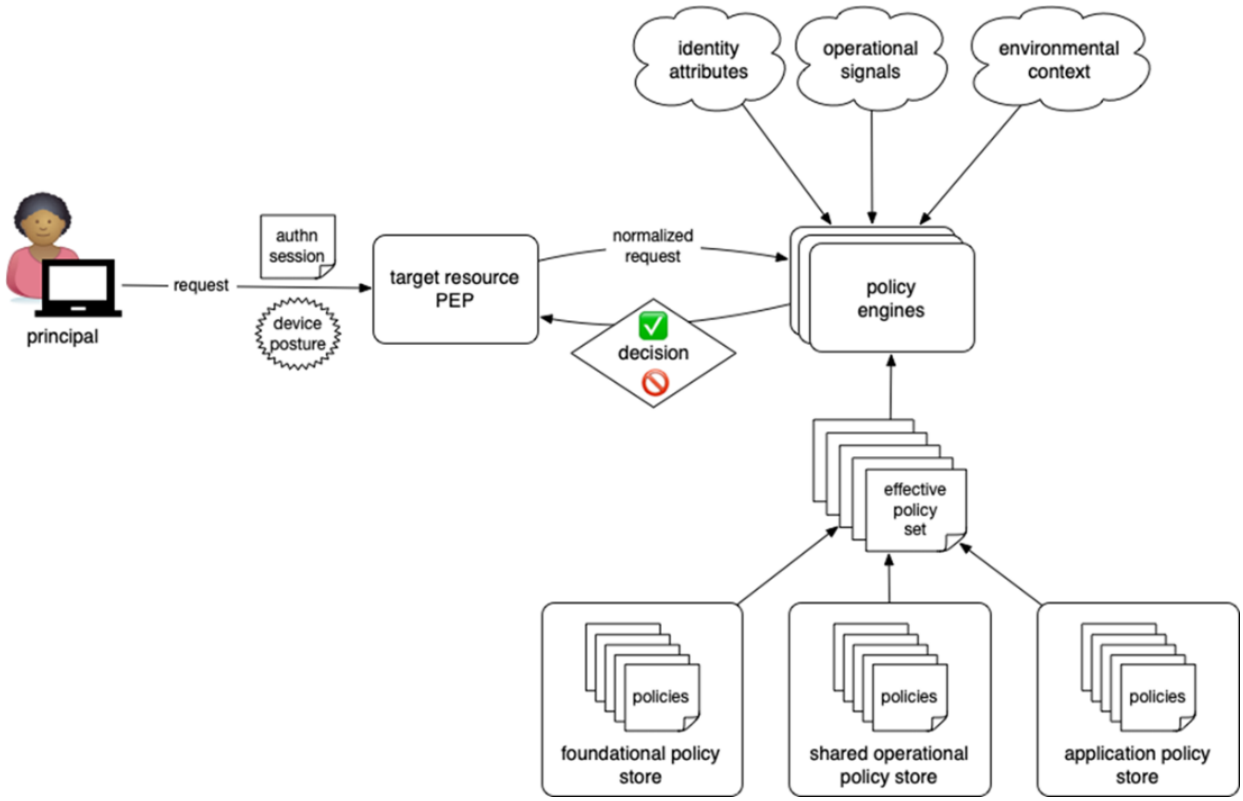


Figure 15.4 Access control in a zero-trust security architecture. The policy enforcement point (PEP) collects authentication context, device posture, and other request information to create a normalized request for the policy engine. The policy engine forms an effective policy set by selecting relevant foundational, shared operational, and application policies, then evaluates the normalized request once to make a unified authorization decision. The PEP then enforces that decision at the target resource.

This approach allowed ACME to enforce its core requirements across all applications consistently. Device posture checks, authentication-strength criteria, and other organization-wide rules were evaluated alongside application and shared operational policies for every request. For example, if Alice tried to view a finance report from a laptop that didn't meet the foundational device-posture requirement described in section 15.3.1, the device policy resulted in a `forbid`. Even if the finance application's own policies would otherwise permit access, Cedar's "forbid overrides permit" semantics mean the overall decision is still `deny`. These core requirements ensured that common security standards were upheld everywhere, across all applications and services.

Shared operational policies added a second layer of refinement for how access decisions were made in practice. These policies defined rules that applied across multiple systems or workflows—often involving conditions